4) Ransomware: Encrpts the victims files & demands payment to restore ac

5) Spyware: Secretly monitors activity & personal information.

27.8.26

Case Study 1:

→ BrightMart is a medium sized online shoppi company. Customers use it's website & mobile application to purchase products.

→ The Company Stores:

1. Customer names
2. Email addresses
3. Phone numbers
4. Delivery addresses
5. Passwords
6. Order & payment information.

→ Brightmart has around 100 employees.

→ The company recently hired several new employees. To make things easier the IT department gave employees access to different internal systems.

→ However, theres the following security weakne

1. Some employees use simple passwords such as BrightMart123.
2. Many employees use the same password for multiple systems.
3. Software updates are sometimes delayed.
4. The company does not conduct employee cybersecurity training.
5. There is no multi-factor authentication for some important accounts.
6. Employees can access sensitive information they do not need for their jobs.

M T W T F S S
Page No.:
Date:
YOUVA SELLAR

7. Backups are performed only once a month.

The incident

→ One Monday morning, an employee named Rahul receives an email
→ Subject: Urgent - Your Account Will Be Suspended
→ The email appears to come from the IT departm
It says:
"Your account will be suspended today. Click the link below & verify your password."
→ Rahul clicks the link.
→ The page looks almost same to the company's login page.
→ He enters his username & password.
→ He doesn't realize that it was from an attaker.
→ The attacker now has Rahul's login credentials.

Stage 1 - Unauthorized Access

→ The attaker uses Rahul's credentials to access Bright Mart's internal system.
→ Rahul uses the same password for another system. The attaker also is able to access tha
→ The attaker discovers Rahul has access to customer information & downloads large
→ amounts of customer data.
→ What cybersecurity problem has occured?

Stage 2 - Malware Attack

→ The attaker sends another email containing a malicious attachment.
→ Rahul opens the attachment
→ Malware is installed on his computer.
→ It begins communicating with the attaker's system.

→ The attacker now attempts to move from Rahul's computer to other systems in Bright
→ Which vulnerability allowed the attacker to move further into the organization?

✱ Stage 3 - Ransomware

→ Two days later, employees arrive at work & discover they cannot access important files. A message appears:
→ "Your files have been encrypted. Pay the Ransom to recover them."
→ The customer database & important business files are encrypted.
→ Unfortunatly, the backup is a month old.
→ The website stops working.
→ Customers cannot place orders.
→ The customer-support team cannot access record

✱ Stage 4 - Business Impact

→ BrightMart now faces several Problems.
→ Finance: Loses sales because website is unavailable
→ Data: Customer Information may have been stolen
→ Operational: Employees can't access important systems
→ Reputation: Customers lose confidence in company
→ Legal: They may face regulatory or legal consequences depending on what information was exposed & which laws apply.

✱ Group 1 - Identify Threats

Q What threats are present in this case?
→ Phishing
→ Malware or Randsomware
→ Credential theft & Data theft

→ Unauthorized access

★ Group 2 - Identify the Vulnerabilities

Q What weaknesses in BrightMart's security allowed the attack to succeed?

Vulnerability	How it helped
→ Weak passwords	Easier to compromis accounts
→ Password Reuse	Access to multiple systems
→ No MFA	Stolen passwords are enough to log in
→ Lack of training	Employee falls for phishing
→ Delayed Updates	Vulnerable software may be exploited.
→ Excessive privileges	Access to more data
→ Infrequent backups	Difficult to recover.

★ Group 3 - Apply the CIA Triad

Q Was confidential information exposed?

→ Yes. Customer information was accesseed / downloaded by the attacker.

Q Was information changed or damaged?

→ Potentially yes.
The attacker could modify or encrypt files.

Q Were systems available to legitimate users?

→ No.
The website & internal systems were unavailable

★ Group 4 - Security Solutions

Q Who is responsible for cybersecurity?

→ Not only the IT department. Every employee who uses the organization's systems has a role in cybersecurity.

Q Was phishing the only problem?

→ No.

Phishing was the initial attack, but weakness like password reuse, no MFA, poor backups, etc allowed the attack to become much more damaging.

Q What was the biggest vulnerability?
→ Lack of employee awareness was the biggest vulnerability because the attack would not have happend if Rahul did not clicked on the link.

Flow Tasks

2-9-26 Attackers exploit systems, networks & human psychology
→ DoS or DDoS (Denial-of-Service) Overwhelming a target server with massive